PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Interconnexion SI à Internet

03-390 ANSSI - Recommandations relatives à l'interconnexion d'un SI à Internet — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La passerelle Internet sécurisée doit utiliser des équipements physiques dédiés pour éviter la mutualisation des pare-feux interne et externe.
2. Le protocole DNS doit être strictement contrôlé en bloquant tout canal direct ou indirect depuis le SI interne pour prévenir l'exfiltration de données.
3. La sécurisation de la messagerie repose sur l'usage de protocoles de vérification comme SPF, DKIM et DMARC complétés par DNSSEC.

Menaces liées à l'interconnexion

Menace	Impact potentiel
Exfiltration de données	Sortie de données non autorisée
Intrusion	Atteinte à l'intégrité ou à la disponibilité
Usurpation d'identité	Rebond vers d'autres cibles
Déni de service	Indisponibilité du service
Accès des collaborateurs	Consultation de sites interdits

Architecture et fonctions de sécurité

Notion	À retenir
Filtrage et cloisonnement	Pare-feu **externe** (Internet/DMZ) et **interne** (SI/DMZ) **non contournables** avec matrice de flux revue. Passerelle Internet sécurisée **incontournable**.
Cinématique des flux	Pas de flux initié depuis la passerelle vers le SI. Flux d'accès : **client SI** → passerelle → Internet. Flux d'hébergement : **client Internet** → passerelle.
Rupture et authentification	Rupture protocolaire recommandée (sauf **tunnel VPN**). Analyse des flux pour détecter **fuite de données** ou **code malveillant**. Pas de requête directe de l'annuaire SI par la passerelle.

Synthèse de l'architecture détaillée et mutualisation

Notion	À retenir
Zones et virtualisation	Passerelle en **5 zones** : accès interne, services internes, services exposés, services relais, accès externe. Risques : **déni de service** et **compromission facilitée**. Mutualisation : besoins et exposition **homogènes** (ex: **Spectre/Meltdown**).
Niveaux d'architecture	Plus sûr : équipements physiques dédiés par zone. Moins sûr : commutation mutualisée par **VLAN**. Proscrire la mutualisation des **pare-feux interne et externe**.
Cas du DNS	Résolveurs **distincts** pour l'interne et le public. **Aucune communication** entre eux. Pare-feu interne : **bloquer par défaut** les flux DNS (anti-exfiltration).
Multi-sites et Cloud	Multi-sites : même architecture et produits. Cloud (relais) : service **SecNumCloud** et tunnel **VPN IPsec** à l'état de l'art, sinon **analyse de risque renforcée**.

Sécurisation de l'interconnexion

Notion	À retenir
Administration et disponibilité	**Administration** : selon le guide dédié de l'**ANSSI**. **Disponibilité** : résilience opérateurs, génie civil, redondance matérielle/logicielle et protection **anti-DDoS**. **Routage** : privilégier le **statique**, désactiver le dynamique, route par défaut du **pare-feu interne** jamais vers Internet.
Confidentialité de l'architecture	**Refus** : mode `DROP` (aucune réponse) plutôt que `REJECT`. **Anonymisation** : des champs techniques divulguant l'infrastructure interne si possible (mesure **complémentaire** et **non prioritaire**).

Sécurisation de l'accès aux contenus Web

Notion	À retenir
Serveur mandataire	Mis en place dans la **zone de services relais** ; accès exploités de manière **centralisée**. Authentification **individuelle** (utilisateurs) ou **non ambiguë** (services).
Inspection TLS	Recommandée pour détecter les **codes malveillants** via **HTTPS**. Complémentaire aux postes. Utiliser une **liste de sites de confiance non inspectés** (vie privée).
Poste de travail	Déploiement d'un **seul navigateur** (surface d'attaque réduite). Mandataire en **mode explicite** (non transparent) pour interdire les **résolutions DNS publiques**.

Synthèse de la sécurisation de la messagerie

Notion	À retenir
Architecture/Cloisonnement	Boîtes aux lettres en **SI interne**. Serveur relais interne dédié (non chaîné à un SMTP exposé) et serveur SMTP en **passerelle**. SMTP envoi/réception sur **machines distinctes**.
Antispam/Accès	Mécanismes : **listes**, **heuristique**, **test de Turing**, **antivirus** et **analyse liens**. Pas de **Webmail public** ; si accepté : **authentification double facteur** et détection renforcée.
Canaux de transport	Flux chiffrés (**SMTPS**, **POPS**, **IMAPS**, **HTTPS**). **STARTTLS** activé (tolérant, désactiver chiffrement implicite port **465**). **REQUIRETLS** recommandé pour entités matures.
Courriels illégitimes	**SPF**, **DKIM**, **DMARC** supportés en réception et configurés en envoi. **DNSSEC** recommandé pour fiabiliser les résolutions publiques de ces protocoles.

Pièges et confusions

- ⚠ Croire que la mutualisation des pare-feux sur un même équipement physique est acceptable via la virtualisation.
- ⚠ Confondre l'activation de STARTTLS avec une garantie de chiffrement systématique de la session SMTP.
- ⚠ Penser que SPF, DKIM et DMARC protègent contre le typosquattage ou le contenu piégé d'un courriel.
- ⚠ Oublier que le protocole DNS peut servir de canal d'exfiltration de données pour un attaquant.

Sigles et définitions

DMZ	sous-réseau séparant deux zones de confiance hétérogène grâce à des pare-feux.
Passerelle Internet sécurisée	constituée d'une ou plusieurs DMZ servant à la rupture protocolaire et à l'analyse du trafic.
Rupture protocolaire	consiste à casser en entrée et reconstruire en sortie la communication au niveau d'une couche OSI.
STARTTLS	option activant le chiffrement et l'authentification d'une session SMTP si le serveur distant le supporte.
DNSSEC	extension du DNS garantissant la fiabilité des données publiées.
SPF, DKIM, DMARC	trois protocoles complémentaires de vérification de l'authenticité et de l'intégrité des courriels via DNS.

Auto-test

1. Quelle est la conséquence d'une mutualisation des pare-feux interne et externe ?
2. Que se passe-t-il si le serveur distant ne supporte pas le STARTTLS ?
3. Quel mode de réponse est refusé pour la confidentialité de l'architecture ?
4. Comment doit être configuré le mandataire sur le poste de travail ?
5. Quelle est la recommandation pour le routage ?

Réponses : **1.** Une compromission unique donnerait un accès direct entre le SI interne et Internet. · **2.** La communication se poursuit en clair. · **3.** Le mode REJECT (le mode DROP est privilégié). · **4.** En mode explicite (non transparent). · **5.** Privilégier le statique et désactiver le dynamique.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.